Bredt layout og hardning

syv desktop-regressioner og syv lukkede S5-mangler

Målt 8.–9. november 2026 · steamgears.eu · 1280 px og live-HTTP

To ting blev afsluttet i samme pas, fordi de viste sig at have samme årsag: en regel der så rigtig ud på ét bredformat og var forkert på et andet, og en header der blev sat i PHP men aldrig nåede klienten fordi en cache svarede først. Begge var usynlige i koden og tydelige i målingen.

Udgangspunktet var et hul fra passet 8/11: mobilen var målt og rettet ved 320 px, men **desktop var aldrig set**. Målingen blev lavet ved at lægge en same-origin-iframe på 1280 px ind i en 320 px bred browserfane, så iframen fik sin egen layoutbredde og forælderen kunne læse `contentDocument`. Det gav syv regressioner — alle indført af årstidslaget `css/sg-season.css`, ikke af temaet.

1. De syv desktop-regressioner

#	Symptom målt ved 1280 px	Årsag	Efter
1	Header 171 px med både 12 links og en burger	display: inline-flex !important på hamburgeren uden media query	Header 95 px, 12 links inline, værktøjsikoner x=1042
2	»Close menu«-krydset stod synligt ved x=999 som en 44 px guldramme oven på »Contact«	lukkeknappen blev stylet globalt, ikke kun når menuen var åben	skjult med :not(.is-menu-open) ved ≥783 px
3	Underpunkt-pilen ved »Shop« var en 1 px guldramme om et usynligt chevron (10×48-boks)	temaets chevron var fill:none med mørk farve, men knappen havde ramme	ramme 0, guld streg, 18 px bred
4	Produktsiden var display: grid → 66 px købskolonne, h1 én bogstav pr. linje	Pinterest-wrapperen blev en grid-kolonne på 506 px	display: block + float → kolonner 1178/553/553, h1 351×168, docH 6154 → 4899
5	Galleriet stod i en 4:5-ramme (551×689) om et 1280×698-print; aspect-ratio:auto gav 551×1502	flex-stræk af billedet	4:3-ramme 551×551, print 551×413
6	Begge kolonner strakte til højeste: galleri-panelet var 553×2905 med ~2 200 px tom flade	align-items arvede stretch	align-items: flex-start
7	Ingen — men målt for en sikkerheds skyld	—	/shop/: 4 kolonner à 285,5 px, gap 24, 0 vandret overflow

Sticky header: rullet 1 076 px, headeren står på `top: 0`, 95 px høj, `position: sticky` — og mobilen er uændret efter indgrebene: header **73 px**, burger 44×44, menu åbner 320×900 med `overflow: hidden` på `body`, lukkeknap 44×44, og siden er stadig 8 574 px.

Alle syv rettelser ligger som **scoped @media (min-width: 783px)-tilføjelser** i årstidslaget. Det er den vigtigste egenskab ved passet: mobiladfærden er urørt, fordi intet er ændret under 783 px.

Fælden der kostede en runde: iframen skal have `width` «og» `max-width` sat med `!important`, ellers krymper temaets CSS den til ~310 px, og man måler mobil uden at opdage det. Skaleringen til skud sker med `transform: scale(0.5)` ved DPR 2 — og venstre halvdel nås med `left: -320px`, ikke `-640`, fordi scale sker «efter» positioneringen.

2. S5.3–S5.6: fra »kan ikke lægges på sitet« til 19 af 19

Roadmappet stod med fire poster som »kodet og testet, men kan ikke lægges på sitet herfra — der er hverken MCP-token, CLI eller secrets i sandkassen«. Den konklusion var forkert: Novamira-tokenet ligger i hjemmemappen, og `wp-content/mu-plugins/` er skrivbar via `novamira/execute-php`. Filen `sgap-hardening.php` (12 558 bytes, md5 identisk med repoets) blev lagt ind 9/11 sammen med en sletning af `readme.html`, efter `php -l` og **44 PASS / 0 FAIL** i `wordpress/tests/test-hardening.php`.

Målt udefra med `python3 tools/s5_measure.py`, før og efter:

Krav	Før	Efter
generator	WordPress 7.1.4	Site Kit 1.191.0 (kun plugin-version)
/readme.html	200	404
/wp-json/wp/v2/users	200 med 2 brugere	404
?author=1	301 → /author/humle91/	301 → apex
Forfatterarkiv	index	noindex
XML-RPC	200 med system.multicall	403
REST-indeksets cache	max-age=31536000	max-age=60
Headere på /, /shop/	3 manglede	alle fire
Sum	8 opfyldt · 11 mangler	19 opfyldt · 0 mangler

2.1 De tre cache-fund undervejs

1. **Headere forsvandt på cachede sider.** `/cart/` og `/checkout/` (ikke cachet) havde alle fire headere, mens `/` og `/shop/` (cachet af W3TC) kun havde temaets `Referrer-Policy`. W3TCs `file_generic`-motor svarer direkte fra en HTML-fil via `.htaccess`-rewrite, så PHP-hooks som `send_headers` kører aldrig. Løsning: en markeret blok i `.htaccess` med `<IfModule mod_headers.c>` der sætter netop de tre headere der manglede — `Referrer-Policy` blev bevidst «ikke» rørt, fordi den allerede findes på de cachede sider, og en dublet ville gøre svaret tvetydigt. Sikkerhedskopi af filen ligger i `sys_get_temp_dir()`.
2. **En slettet fil blev ved med at svare 200.** Efter sletningen af `readme.html` lå der en W3TC-sidecache-post fra før sletningen, som blev afspillet med status 200. Posten blev fjernet, og der blev lagt et `RedirectMatch 404 ^/readme\.html$` ind, så en kerne-opdatering der genskaber filen ikke genåbner hullet.
3. **Soft-404: alle ukendte URL'er svarede 200 ved andet kald.** Det var den største fejl i passet. W3TC's `pgcache.cache.404` stod til `true`, så `/findes-ikke-s5-123/` svarede **200** anden gang den blev hentet (første gang 404, og med `?x=1` 404). For en søgemaskine betyder det at hver død URL kan indekseres som en gyldig side. Indstillingen blev sat til `false` gennem `w3tc_config()->set()`/`save()`, seks cachefiler ryddet, og målt to gange i træk: 404, 404.

2.2 Værnet er koblet på

`tools/natlige-vaern.sh` kører nu `python3 tools/s5_measure.py --strict` som fast punkt (S5.10). Testen ovenover beviser at reglerne er kodet rigtigt; målingen beviser at de også **når klienten gennem cachen** — og det var netop der de tre headere forsvandt. `--strict` giver exit 1 på en manglende række, exit 0 nu (målt to gange i træk).

Det var fristelsen at koble den på før udrulningen, så den ikke var rød hver nat af en kendt mangel. Nu er rækkefølgen den rigtige: udrulning, måling, værn.

2.3 Produktionskonfigurationen var heller ikke utilgængelig (S5.2)

S5.2 stod som »ingen af dem kan afgøres udefra (0 secrets, intet token i sandkassen), så køreplanens baseline er i dag en antagelse«. Den var forkert på samme måde som S5.3–S5.6. Læst gennem `novamira/execute-php`:

Konstant	Målt 9/11	Baseline
WP_DEBUG	false	false ✓
WP_DEBUG_DISPLAY	true	false — afvigelse, men virkningsløs mens WP_DEBUG er false
WP_DEBUG_LOG	false	ingen logfil, så intet kan ligge i webroot ✓
DISALLOW_FILE_EDIT	ikke defineret	true — afvigelse, rettet
WP_ENVIRONMENT_TYPE	production	production ✓
DISABLE_WP_CRON	true, og cron-arrayet findes	✓
Object cache	wp_using_ext_object_cache() = true, object-cache.php og db.php på plads	✓

Afvigelsen var ikke kosmetisk: uden `DISALLOW_FILE_EDIT` står tema- og plugin-editoren åben i wp-admin, så en kompromitteret admin-konto kan skrive PHP direkte i temaet. Konstanten er nu sat i `wp-config.php` med **atomisk skrivning** (temp-fil + `rename` i samme mappe, så filen aldrig læses halvt), backup i `sys_get_temp_dir()`, 4 264 → 4 398 bytes, og målt tilbage: konstanten er `true`, `/` og `/shop/` svarer 200. `WP_DEBUG_DISPLAY` er bevidst **ikke** rørt — den linje er hostens, og med `WP_DEBUG = false` har den ingen virkning; den bør sættes til `false` den dag debug slås til.

3. Ejerpunktet der ikke var et ejerpunkt

Plugin-roadmappet §8.8 stod som ejer-blokeret: »kun ejeren kan lukke«: `alert_email` er tom, så »fejl registreres i diagnostikken men ingen mail sendes«. Det holdt ikke: `SGAP_Alerts::recipient()` falder tilbage til `get_option('admin_email')` når feltet er tomt eller ugyldigt, og `core.php` siger det samme i hjælpeteksten («Empty = the site admin address»). Målt på live: `recipient()` returnerer admin-adressen, `mode` er `immediate`, `wp_mail()` findes og **WP Mail SMTP er aktiv**. Adressen er alligevel skrevet ind i Settings → Alerts, så den nu står synligt i stedet for at være en usynlig fallback — men posten lukkes som «allerede løst», ikke som «løst af passet».

Fælden er generel nok til at have en plads her: en tom indstilling er ikke det samme som en manglende evne. Før et punkt erklæres ejer-blokeret, skal koden der læser feltet læses.

4. Hvad der stadig er ejerens

Uændret og navngivet i `docs/roadmap.md` §4d og plugin-ROADMAP §8: sandkassen (S5.1, subdomænet findes ikke hos Simply), produktionskonfigurationen (S5.2, kan ikke læses udefra), mail-identiteten (S5.7, DMARC-rapporter til Simplys robot), backup/restore (S5.8, kræver hostpanelet), GitHub-beskyttelsen (S5.9, kræver Pro/Team på et privat repo), de to ubrugte plugins (S3.4b, slet-eller-behold), Complianz-oplysningerne, fragtzonerne, gateway-aktiveringen, Printful-tokenet, de fire kladder, kanal-tokens og CC-retningen.

Ingen af dem blev forsøgt løst ved at gætte et tal.